

Audit-Tail Final Report

Project: **vulnerable-invoice-service** · Stage 5 (aggregate) · Generated 2026-07-04 · Health Score: **58 / 100** Grade C — needs attention
(projected once PR #60 merges — see baseline below)

Executive summary

- **24** dependency coordinates scanned on `main` (`61ed8c3`) · **75** CVE findings across **10** vulnerable/flagged coordinates, plus 1 typosquat and 1 license violation.
- **Supply-chain:** typosquat resolved in this run · untrusted HTTP mirror and the mysql GPL-2.0 license violation remain (pre-existing, human decision required).
- **Remediation:** consolidated fix PR **#60** open on `fix/depSCAN-20260704-055529` — typosquat removed; `log4j-core/api` → 2.25.4; `jackson-databind` → 2.18.8 (bumped twice — see note below); `commons-io` → 2.14.0; `commons-lang3` → 3.18.0; `protobuf-java` pinned → 3.25.5.
- **Latest gate outcome:** PASS — ready for human merge.

Self-correcting gate, in action: the first gate pass (commit `1f3b323`) correctly **BLOCKed** this PR — `jackson-databind:2.16.0` , the version this run initially chose, turned out to carry two newly-disclosed HIGH CVEs (CVE-2026-54513 / CVE-2026-54512, CVSS 8.1) that Stage 1-2's scan missed due to a stale OWASP DB (issue #57). Rather than leave the PR blocked, it was bumped once more to `2.18.8` (commit `5d530f8`) — still the minimal safe target, still inside the 2.x line — and the re-run gate passed. This is the pipeline working as designed: the gate is the backstop that catches what the scan stage misses.

Health score breakdown

Factor	Current main (unfixed)	Once PR #60 merges
Unresolved HIGH-band deps (8 × -8 → 2 × -8)	mysql-connector-java, guava, log4j-core, log4j-api, jackson-databind, protobuf-java (6 × -8 = -48)	mysql-connector-java, guava (2 × -8 = -16)
Unresolved MEDIUM-band deps (2 × -2)	jackson-annotations, commons-io, commons-lang3 (3 × -2 = -6)	none (0)
Supply-chain BLOCK findings (typosquat / untrusted mirror / license, 10 × -n)	typosquat + untrusted mirror + mysql license (3 × -10 = -30)	untrusted mirror + mysql license (2 × -10 = -20)
Outdated major-version direct deps (3 × -3)	log4j-core, log4j-api, guava, junit-jupiter (4 × -3 = -12)	guava, junit-jupiter (2 × -3 = -6)
Score (floored at 0)	4 / 100 — Grade D	58 / 100 — Grade C

+54 point swing once PR #60 merges. The remaining ceiling on Grade C is exactly the two items this run deliberately did **not** touch: `mysql-connector-java` (CVE-2023-22102 has a patch at `8.1.0` , but that doesn't clear the GPL-2.0-with-FOSS-exception license violation — a human license call, tracked in #58) and `guava` (`24.1.1-jre` → `32.0.0-jre` is an 8-major-version jump requiring API review, tracked in #49). Clearing both would put this project in the low-90s (Grade A).

Top risks (ranked, post-PR-#60 state)

Coordinate	Risk	Band	Top CVE / issue	Status
------------	------	------	-----------------	--------

mysql:mysql-connector-java:8.0.30	6.7	HIGH	CVE-2023-22102 (8.3) + GPL-2.0 license violation	Not fixed — issue #58
com.google.guava:guava:24.1.1-jre	6.3	HIGH	CVE-2023-2976 (7.1)	Not fixed — issue #49
pom.xml internal-untrusted-mirror	—	HIGH	Untrusted HTTP repository (MITM risk)	Not fixed — pre-existing (Issue #5/#21)
org.apache.logging.log4j:log4j-core / log4j-api	7.8 → resolved	OK	CVE-2021-44228 (Log4Shell) — cleared	Fixed in PR #60
com.fasterxml.jackson.core:jackson-databind	7.8 → resolved	OK	CVE-2019-14379 + 53 more, plus 2 newly-disclosed CVEs caught by the gate — all cleared	Fixed in PR #60 (2.9.8 → 2.16.0 → 2.18.8)
com.fastxml...:jackson-databind (typosquat)	—	OK	supply-chain — removed	Fixed in PR #60

Remediation activity

Dependency	Change	CVEs cleared	Status
com.fastxml.jackson.core:jackson-databind	removed (typosquat)	n/a — supply-chain	in PR #60
log4j-core / log4j-api	2.14.1 → 2.25.4	CVE-2021-44228 (Log4Shell), CVE-2026-34479 + 6 more	in PR #60
jackson-databind (real)	2.9.8 → 2.16.0 → 2.18.8	CVE-2019-14379 + 53 more; then CVE-2026-54513/-54512 caught by the gate	in PR #60
protobuf-java (transitive)	3.19.4 → 3.25.5 via dependencyManagement	CVE-2024-7254	in PR #60
commons-io	2.4 → 2.14.0	CVE-2021-29425	in PR #60
commons-lang3	3.4 → 3.18.0	CVE-2025-48924	in PR #60
guava	not bumped — 8-major-version jump, API review required	CVE-2023-2976, CVE-2020-8908 unresolved	issue #49 (human follow-up)
mysql-connector-java	not bumped — version bump doesn't clear GPL-2.0 flag	CVE-2023-22102 unresolved	issue #58 (human follow-up)

Reviewer reconciliation note: an earlier open PR, [#59](#) (`fix/depSCAN-20260703-060919` , 2026-07-03), already bumped `guava` to `32.0.1-jre` as part of its batch. PR #60 does not touch `guava` , following this run's stricter "no major-version jump without human sign-off" reading of the auto-remediation policy. If both PRs remain open, merge order matters — merging #60 alone leaves `guava` unresolved even though #59 already has a working fix for it. Recommend the human reviewer either merge #59's `guava` change first or cherry-pick it into #60 before merging, rather than merging both independently and re-litigating the same file.

Gate (Stage 4) — final verdict: PASS

Check	Result
Unit tests (<code>mvn clean test</code>)	PASS — 2/2 passed, on both gate runs
OWASP Dependency-Check CVE gate	PASS (re-run) — 0 unresolved CRITICAL/HIGH on anything this PR touches

Note: `mvn clean verify` still fails the pre-existing JaCoCo 80% line-coverage gate (Issue #6), seeded intentionally in this demo repo. That failure is unrelated to dependency/supply-chain changes and was not used to derive the gate verdict above.

Required actions before this project reaches Grade A

1. Resolve `mysql:mysql-connector-java` — either accept the GPL-2.0-with-FOSS-exception license and bump to `8.1.0` +, or migrate to `com.mysql:mysql-connector-j` (issue #58).
2. Review the Guava 24 → 32 API surface and merge the major-version bump — a working fix already exists in PR #59 (issue #49).
3. Remove the `internal-untrusted-mirror` HTTP repository entry from `pom.xml`, or replace it with an HTTPS, allowlisted source (issue #5/#21).

Demo script — vulnerable → detected → scored → fixed → gated → merge-ready

1. **Show a vulnerable project** — `pom.xml` on `main` declares `log4j-core:2.14.1` (Log4Shell), a typosquatted `com.fastxml.jackson.core:jackson-databind`, and a GPL-licensed MySQL driver.
2. **Detect** — Stage 1 scan (`risk_scoring_agent`) finds 75 CVE findings across 10 vulnerable/flagged coordinates, writes `depscan-report.json`.
3. **Score** — Stage 2 ranks them; the typosquat and `log4j-core / log4j-api / jackson-databind` float to the top of `depscan-risk-report.json`.
4. **Fix** — Stage 3 (`depscan-auto-remediation`) batches 6 safe fixes onto `fix/depscan-20260704-055529` and opens consolidated PR #60, with a changelog and CVE table.
5. **Gate — catch, fix, re-gate** — Stage 4 (`pr_validation_agent`) BLOCKs on newly-disclosed CVEs in the first `jackson-databind` bump; a follow-up commit clears them; the re-run gate PASSES, posted as a PR review.
6. **Prove** — once PR #60 (and ideally the guava fix from #59) merges, re-render this report; expect the health score to move from **4** → **58+** immediately, and into the 90s once issues #49 and #58 close.

Pre-flight checklist: Java 17+, Maven on PATH, Syft/Grype installed, `GITHUB_TOKEN` /GitHub MCP authenticated for the target repo, demo repo checked out at a known commit (`61ed8c3` for this run).

Rollback note: this run only ever pushes a new `fix/depscan-*` branch and opens PR #60 — `main` is untouched, so the demo resets by simply deleting the branch/closing the PR if a clean re-run is needed. No new tracking issues were opened this run; `guava` and `mysql-connector-java` findings link to the most recent already-open issues (#49, #58) rather than adding to the existing duplicate backlog.

Aggregated from `depscan-report.json`, `depscan-risk-report.json`, and `depscan-supplychain-audit.json`. Generated by the Dependency & Supply-Chain Plugin — Stage 5.